



INFORME DE INCIDENTE DE SEGURIDAD

Análisis Forense de Intrusión en Servidor Web Debian

Ciente	4Geeks Academy
Proveedor del servicio	NexusTrace S.A.S
Analista responsable	Jose Muñoz A
Sistema afectado	Servidor Debian - IP 192.168.64.9
Fecha del incidente	08 Octubre 2024
Fecha del análisis	5-9 Marzo 2026
Fecha del informe	11 Marzo 2026
Versión	v1.0
Severidad del incidente	CRITICO
Clasificación	CONFIDENCIAL

Control de versiones

Versión	Fecha	Autor	Descripción
v1.0	11 Mar 2026	Jose Daniel Muñoz Arciniegas	Versión inicial — Análisis forense de intrusión SSH. Incidente: 08/10/2024

TABLA DE CONTENIDO

1. Resumen Ejecutivo.....	4
2. Alcance de la Investigación.....	4
3. Metodología de Investigación Forense.....	5
4. Hallazgos del Análisis Forense.....	9
5. Línea de Tiempo del Incidente.....	12
6. Escaneo de Seguridad del Sistema.....	13
7. Análisis de Procesos del Sistema.....	14
8. Acciones Correctivas Implementadas.....	14
9. Validación de Remediaciones.....	17
10. Recomendaciones.....	18
11. Conclusión.....	19

1. Resumen Ejecutivo

Durante la investigación forense realizada sobre el servidor Debian con servicios web y acceso remoto habilitado, se identificó un incidente de seguridad relacionado con un acceso no autorizado mediante SSH. El análisis confirmó que el servicio SSH estaba activo y expuesto, y que el usuario debian había editado previamente el archivo `/etc/ssh/sshd_config` con privilegios de root. Posteriormente, el 08 de octubre de 2024 a las 17:40:59, se registró una autenticación SSH exitosa para el usuario root desde la dirección IP 192.168.0.134, seguida de la apertura de una sesión válida de root.

Se revisaron logs, artefactos del sistema, historial de comandos, archivos modificados y procesos activos. No se encontró evidencia concluyente de actividad persistente posterior a la autenticación ni de instalación de malware o rootkits. Sin embargo, el acceso no autorizado confirma una exposición crítica del sistema asociada a configuraciones inseguras y credenciales débiles. Se aplicaron medidas correctivas orientadas a mitigar el acceso, reducir la superficie de ataque y reforzar la seguridad del servidor.

EVALUACION DE IMPACTO - TRIADA CIA

Confidencialidad: ALTO — El acceso como root permitiría la lectura y exfiltración de cualquier archivo del sistema, incluyendo credenciales de bases de datos, claves privadas y datos de usuarios de WordPress.

Integridad: ALTO — Con privilegios de root, el atacante tendría capacidad para modificar archivos del sistema, binarios, scripts de inicio y configuraciones sin restricción.

Disponibilidad: ALTO — El control total del servidor permitiría la interrupción de todos los servicios activos (SSH, Apache, MariaDB, WordPress, FTP).

HALLAZGO CORROBORADO EN AUTOPSY

Durante el análisis de la imagen forense en Autopsy se revisaron artefactos del sistema de archivos y logs del sistema, donde se identificaron eventos relacionados con la actividad del servicio SSH y la autenticación del usuario root. Estos hallazgos coincidieron con los eventos observados posteriormente mediante el análisis directo del sistema utilizando comandos de terminal.

2. Alcance de la Investigación

Sistema operativo: Debian Linux

Servicios investigados: SSH, Apache Web Server, MariaDB, WordPress, FTP

Dirección IP del servidor comprometido: 192.168.64.9

Fuera del alcance de la investigación:

Análisis de tráfico de red; análisis de memoria RAM en tiempo real (imagen adquirida en estado offline); revisión de otros sistemas en la red que pudieran haber sido alcanzados desde 192.168.64.9; atribución del atacante más allá de la dirección IP de origen.

3. Metodología de Investigación Forense

La investigación siguió los principios de la forensia digital definidos en NIST SP 800-86 (Guide to Integrating Forensic Techniques into Incident Response) e ISO/IEC 27037 (Directrices para la identificación, recopilación, adquisición y preservación de evidencia digital), garantizando la integridad, reproducibilidad y trazabilidad de los hallazgos.

Herramientas utilizadas

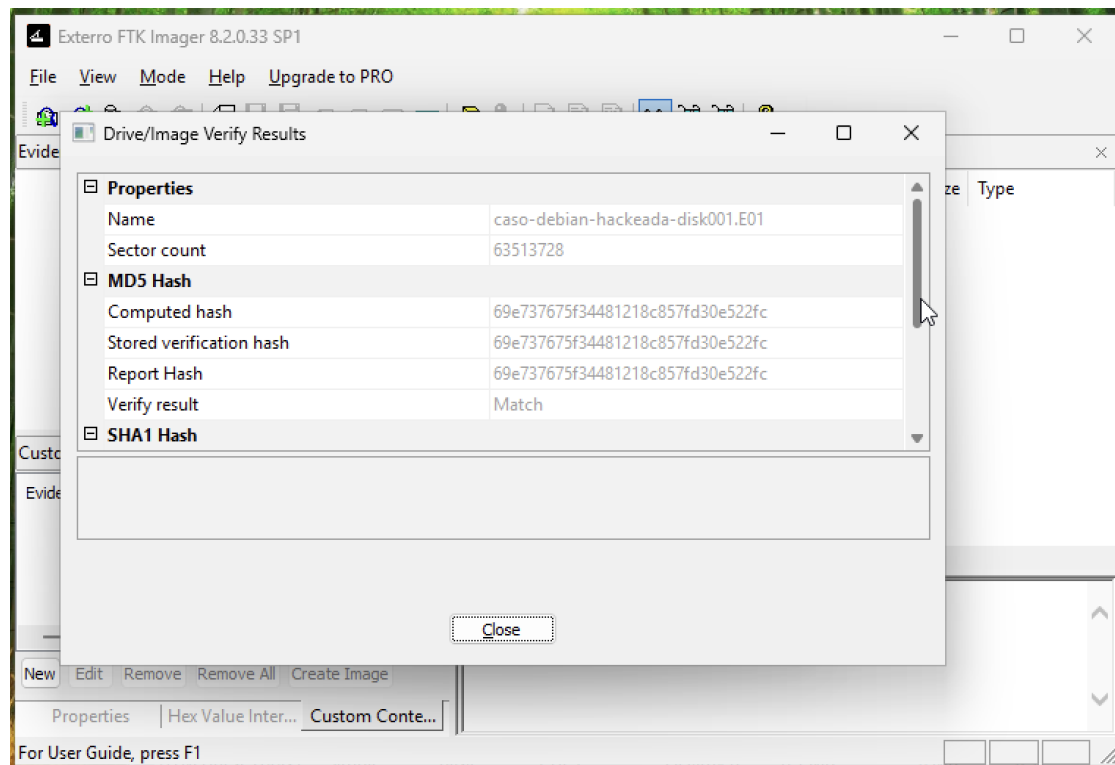
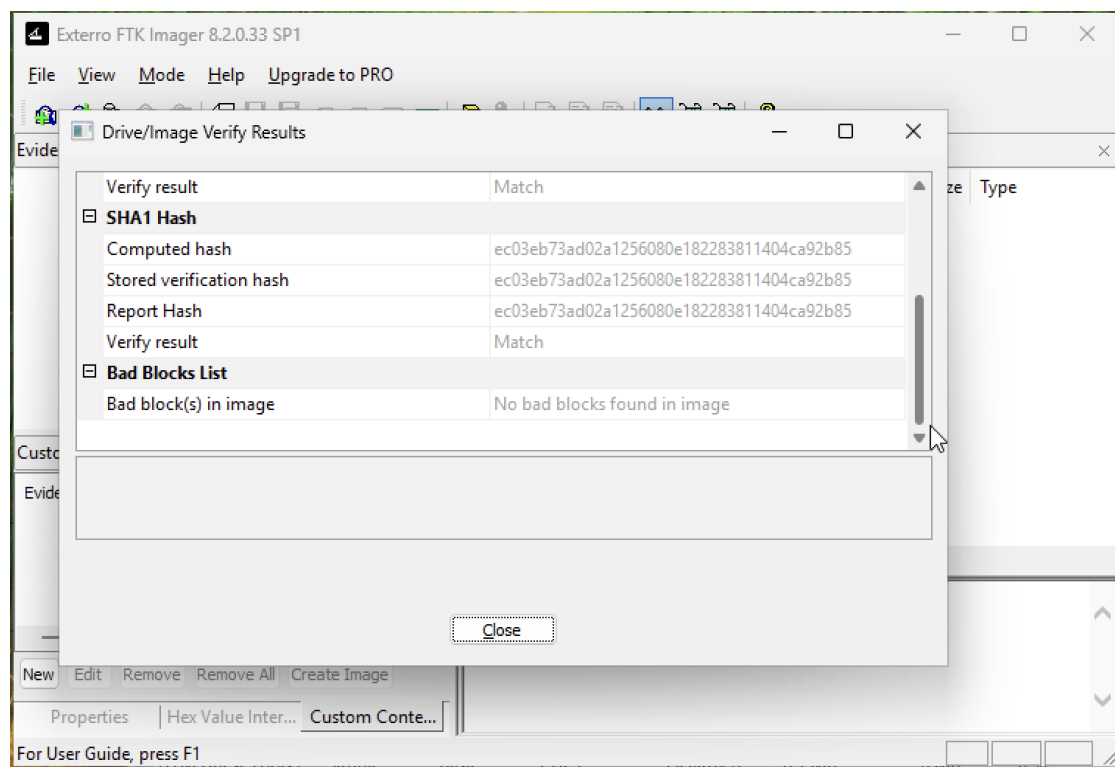
Herramienta	Versión	Uso
FTK Imager / ewfacquire	—	Adquisición forense en formato E01 con cadena de custodia
Autopsy	8.2.0.33	Análisis forense del sistema de archivos, logs y artefactos
journalctl (systemd)	—	Consulta y filtrado de logs del sistema operativo
chkrootkit	—	Detección de rootkits y verificación de integridad del sistema
rkhunter	—	Detección de rootkits y verificación de integridad
ss / netstat	—	Análisis de puertos y conexiones de red activas
bash_history	—	Revisión de historial de comandos ejecutados

3.1 Adquisición Forense de Evidencia y Cadena de Custodia

Se generó una imagen forense del sistema en formato E01. Durante la adquisición se calcularon hashes MD5 y SHA1 para preservar la integridad de la evidencia. Cualquier análisis posterior se realizó exclusivamente sobre la imagen forense, preservando el sistema original sin modificaciones.

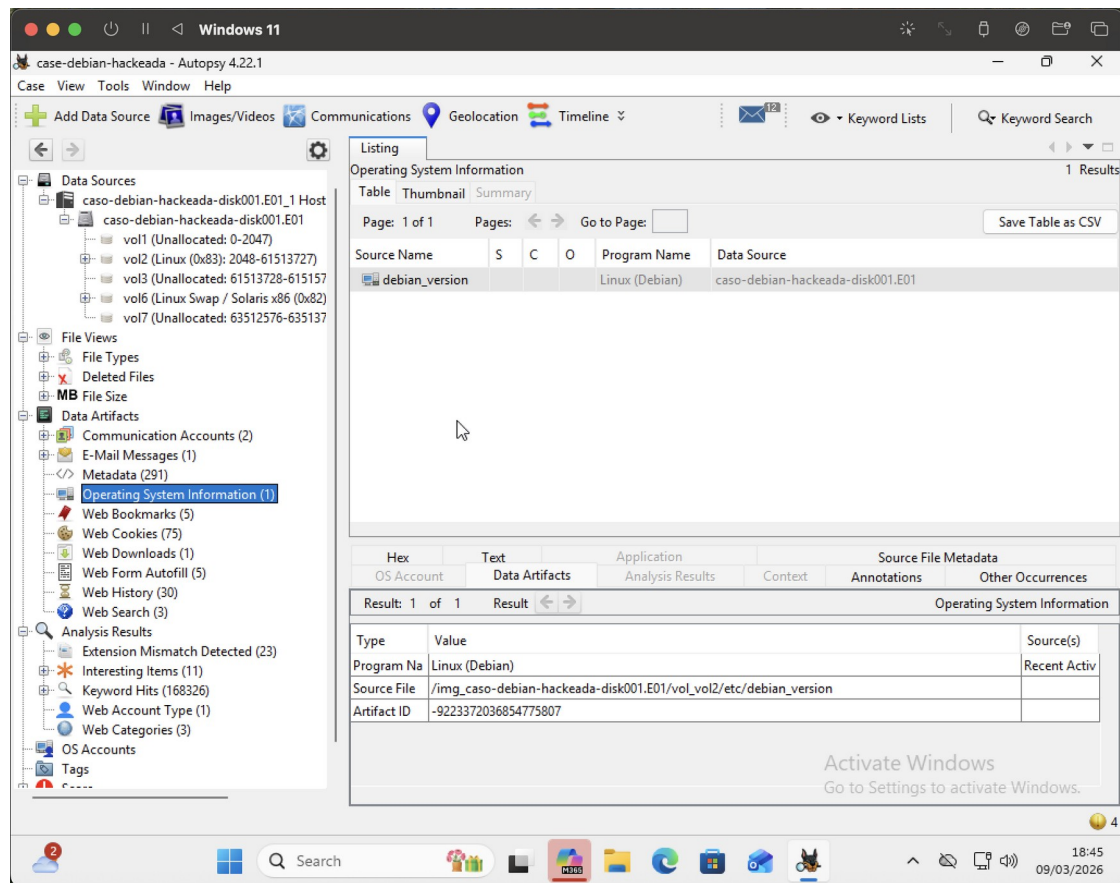
Cadena de Custodia de Evidencia

Evidencia	Descripción	Hash MD5	Hash SHA1	Fecha	Analista
Imagen forense E01	Servidor Debian (192.168.64.9)	69e737675f34481218c857fd30e522fc	ec03eb73ad02a1256080e182283811404ca92b85	05/03/2026	Jose D. Muñoz

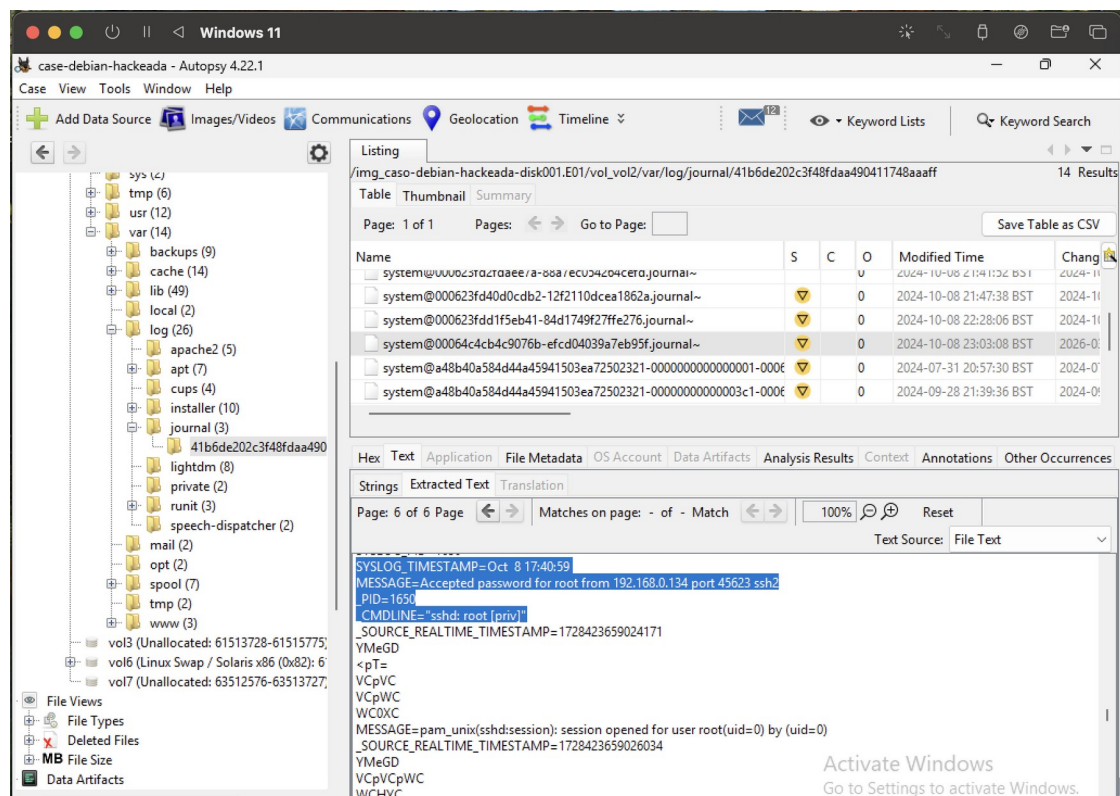
*Adquisición forense de imagen E01**Verificación de hashes de integridad*

3.2 Análisis Forense con Autopsy

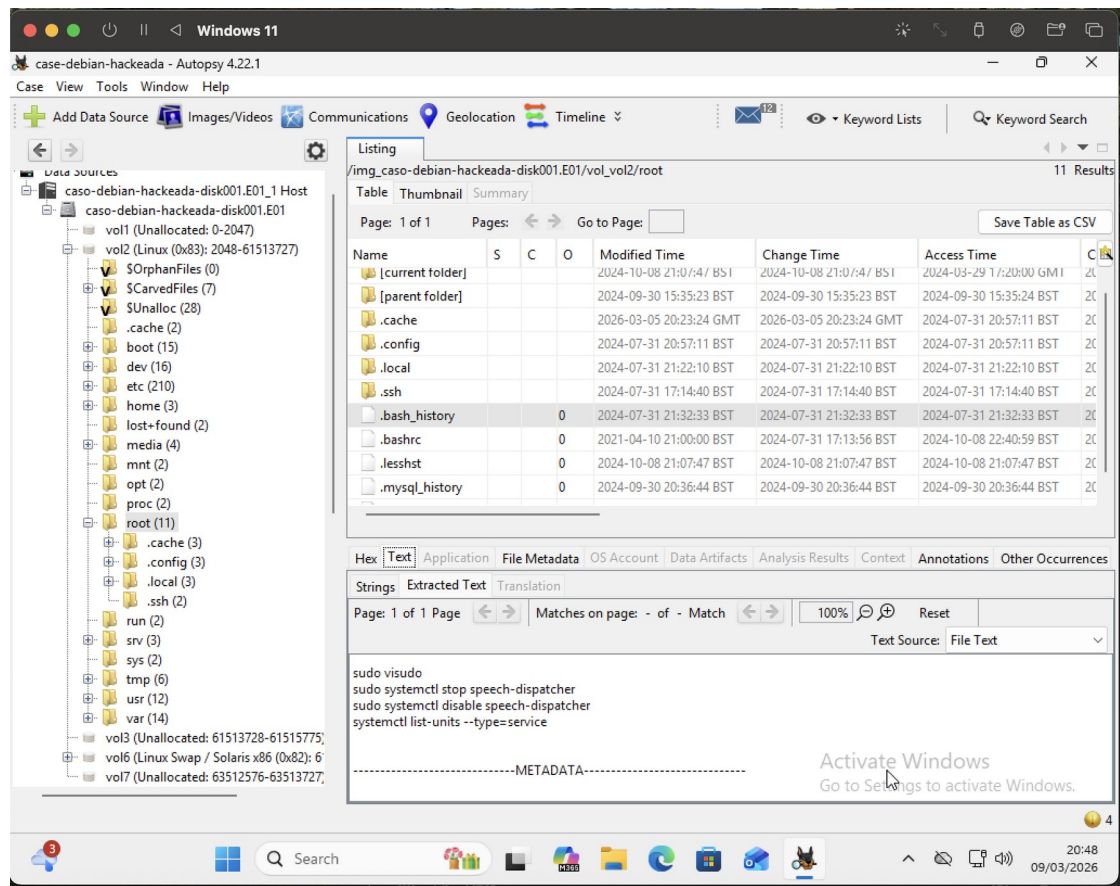
La imagen fue analizada utilizando Autopsy, ejecutado en una máquina virtual Windows 11 en UTM.



Interfaz de Autopsy con la imagen forense cargada



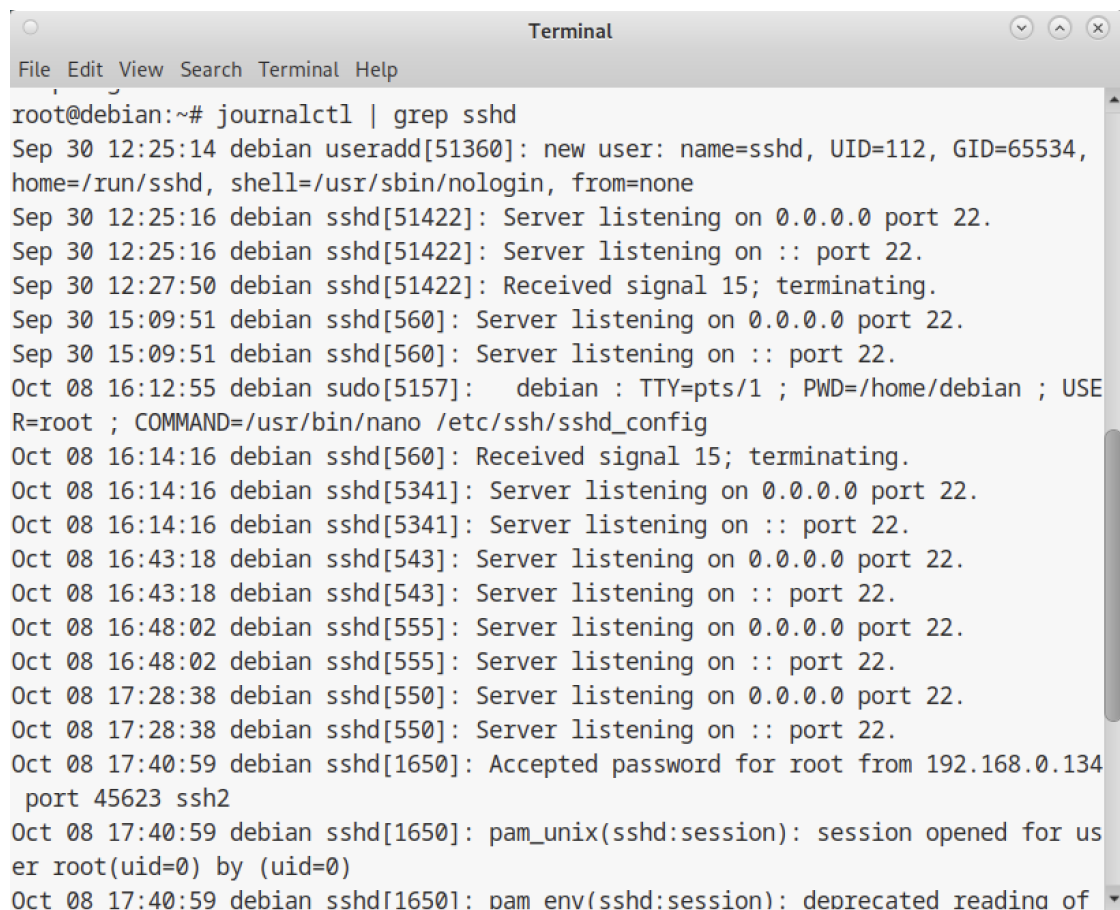
Estructura del sistema de archivos en Autopsy



Artefactos del sistema identificados en Autopsy

3.3 Análisis de Logs

Dado que el archivo `/var/log/auth.log` no estaba presente, la investigación se realizó sobre el journal del sistema utilizando `journalctl`.



```
root@debian:~# journalctl | grep sshd
Sep 30 12:25:14 debian useradd[51360]: new user: name=sshd, UID=112, GID=65534,
home=/run/sshd, shell=/usr/sbin/nologin, from=none
Sep 30 12:25:16 debian sshd[51422]: Server listening on 0.0.0.0 port 22.
Sep 30 12:25:16 debian sshd[51422]: Server listening on :: port 22.
Sep 30 12:27:50 debian sshd[51422]: Received signal 15; terminating.
Sep 30 15:09:51 debian sshd[560]: Server listening on 0.0.0.0 port 22.
Sep 30 15:09:51 debian sshd[560]: Server listening on :: port 22.
Oct 08 16:12:55 debian sudo[5157]:  debian : TTY=pts/1 ; PWD=/home/debian ; USE
R=root ; COMMAND=/usr/bin/nano /etc/ssh/sshd_config
Oct 08 16:14:16 debian sshd[560]: Received signal 15; terminating.
Oct 08 16:14:16 debian sshd[5341]: Server listening on 0.0.0.0 port 22.
Oct 08 16:14:16 debian sshd[5341]: Server listening on :: port 22.
Oct 08 16:43:18 debian sshd[543]: Server listening on 0.0.0.0 port 22.
Oct 08 16:43:18 debian sshd[543]: Server listening on :: port 22.
Oct 08 16:48:02 debian sshd[555]: Server listening on 0.0.0.0 port 22.
Oct 08 16:48:02 debian sshd[555]: Server listening on :: port 22.
Oct 08 17:28:38 debian sshd[550]: Server listening on 0.0.0.0 port 22.
Oct 08 17:28:38 debian sshd[550]: Server listening on :: port 22.
Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134
port 45623 ssh2
Oct 08 17:40:59 debian sshd[1650]: pam_unix(sshd:session): session opened for us
er root(uid=0) by (uid=0)
Oct 08 17:40:59 debian sshd[1650]: pam_env(sshd:session): deprecated reading of
```

Consulta del journal del sistema con journalctl

4. Hallazgos del Análisis Forense

4.1 Exposición del servicio SSH

Se confirmó que el servicio SSH se encontraba escuchando en todas las interfaces:

```
0.0.0.0:22 :::22
```

Esta configuración implica que el servicio SSH es accesible desde cualquier dirección de red, incluyendo redes externas, lo que amplía significativamente la superficie de ataque del servidor.

```
Sep 30 12:25:14 debian useradd[51360]: new user: name=sshd, UID=112, GID=65534,
home=/run/sshd, shell=/usr/sbin/nologin, from=none
Sep 30 12:25:16 debian sshd[51422]: Server listening on 0.0.0.0 port 22.
Sep 30 12:25:16 debian sshd[51422]: Server listening on :: port 22.
Sep 30 12:27:50 debian sshd[51422]: Received signal 15; terminating.
Sep 30 15:09:51 debian sshd[560]: Server listening on 0.0.0.0 port 22.
```

SSH escuchando en todas las interfaces de red

4.2 Modificación previa de la configuración SSH

El journal del sistema registró que el usuario debian editó el archivo de configuración del servicio SSH con privilegios de superusuario:

```
Oct 08 16:12:55 debian sudo[5157]: debian : TTY=pts/1 ; PWD=/home/debian ; USER=root ;
COMMAND=/usr/bin/nano /etc/ssh/sshd_config
```

La revisión del archivo `/etc/ssh/sshd_config` reveló que se habían habilitado las siguientes directivas que permiten el acceso como root mediante contraseña:

`PasswordAuthentication yes`

`PermitRootLogin yes`

Esta combinación de parámetros representa la causa raíz directa del incidente, ya que eliminó las barreras de seguridad que por defecto restringen el acceso remoto privilegiado.

```
Oct 08 16:12:55 debian sudo[5157]:  debian : TTY=pts/1 ; PWD=/home/debian ; USER=root ; COMMAND=/usr/bin/nano /etc/ssh/sshd_config
Oct 08 16:14:16 debian sshd[560]: Received signal 15; terminating.
Oct 08 16:14:16 debian sshd[5341]: Server listening on 0.0.0.0 port 22.
Oct 08 16:14:16 debian sshd[5341]: Server listening on :: port 22.
Oct 08 16:43:18 debian sshd[5431]: Server listening on 0.0.0.0 port 22.
```

Directivas inseguras habilitadas en sshd_config

4.3 Reinicio del servicio SSH

Tras la modificación del archivo de configuración, se observaron eventos de parada e inicio del servicio `ssh.service`:

`Oct 08 16:14:16 debian systemd[1]: Stopping ssh.service`

`Oct 08 16:14:16 debian systemd[1]: Starting ssh.service`

El reinicio del servicio a las 16:14:16 activó la nueva configuración insegura, dejando una ventana de aproximadamente 86 minutos antes del acceso no autorizado registrado a las 17:40:59.

4.4 Acceso SSH no autorizado

El journal registró una autenticación SSH exitosa para el usuario root desde un host externo:

`Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134 port 45623 ssh2`

El método de autenticación fue contraseña (password), posibilitado por la directiva `PasswordAuthentication yes` habilitada en el paso anterior. El acceso se originó desde la dirección IP 192.168.0.134, puerto efímero 45623.

```
Oct 08 17:28:38 debian sshd[550]: Server listening on :: port 22.
Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134 port 45623 ssh2
Oct 08 17:40:59 debian sshd[1650]: pam_unix(sshd:session): session opened for user root(uid=0)
```

Registro de autenticación SSH exitosa como root

4.5 Apertura de sesión privilegiada

Inmediatamente tras la autenticación exitosa, el sistema registró la apertura de una sesión con privilegios de superusuario (UID=0):

`pam_unix(sshd:session): session opened for user root(uid=0)`

Esto confirma que el atacante obtuvo acceso interactivo completo al sistema con los máximos privilegios disponibles en Linux.

```
Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134
port 45623 ssh2
Oct 08 17:40:59 debian sshd[1650]: pam_unix(sshd:session): session opened for us
er root(uid=0) by (uid=0)
Oct 08 17:40:59 debian sshd[1650]: pam env(sshd:session): deprecated reading of
```

Sesión privilegiada abierta para root (UID=0)

4.6 Ausencia de evidencia concluyente de actividad posterior

Se analizó el historial de comandos del usuario root para identificar actividad post-acceso:

```
cat /root/.bash_history
```

La revisión del historial de comandos del usuario root no reveló evidencia de actividad maliciosa posterior al acceso. No se encontraron comandos asociados a exfiltración de datos, modificación de archivos críticos del sistema, instalación de software o establecimiento de mecanismos de persistencia.

Adicionalmente, el escaneo con herramientas de detección de rootkits (secciones 6 y 7) no identificó evidencia de persistencia en el sistema. La ausencia de actividad concluyente puede deberse a que el atacante borró el historial, a que la sesión fue breve, o que el propósito del acceso fue de reconocimiento.

```
root@debian:~# cat /root/.bash_history
sudo visudo
sudo systemctl stop speech-dispatcher
sudo systemctl disable speech-dispatcher
systemctl list-units --type=service
root@debian:~#
```

Historial de comandos del usuario root

4.7 Indicadores de Compromiso (IOCs)

Los siguientes indicadores fueron identificados durante la investigación y deben ser utilizados para correlación con otros sistemas y para monitoreo preventivo:

Indicador	Tipo	Valor	Descripción
IP atacante	IP Address	192.168.0.134	Dirección de origen del acceso SSH no autorizado
Puerto	Port	45623	Puerto efímero utilizado en la conexión SSH
Usuario objetivo	Account	root (uid=0)	Cuenta con la que se realizó la autenticación
Timestamp	DateTime	2024-10-08 17:40:59	Momento exacto del acceso registrado en el journal

Indicador	Tipo	Valor	Descripción
Archivo modificado	File	/etc/ssh/sshd_config	Modificado a las 16:12:55 para habilitar PasswordAuthentication y PermitRootLogin
Servidor	Host	192.168.64.9	Servidor Debian afectado

4.8 Clasificación MITRE ATT&CK

Los eventos identificados durante la investigación se corresponden con las siguientes tácticas y técnicas del marco MITRE ATT&CK (Enterprise):

Táctica	Técnica	ID	Observación en el incidente
Defense Evasion / Persistence	Modify Authentication Process	T1556	Modificación de sshd_config para habilitar PasswordAuthentication yes y PermitRootLogin yes
Lateral Movement / Initial Access	Remote Services: SSH	T1021.004	Acceso SSH desde 192.168.0.134 al servidor
Privilege Escalation	Valid Accounts: Local Accounts	T1078.003	Login directo como root — máximos privilegios sin escalación adicional necesaria

5. Línea de Tiempo del Incidente

Todos los timestamps corresponden a la zona horaria de Bogotá (UTC -5):

Timestamp	Evento
2024-10-08 16:12:55	Usuario debian edita /etc/ssh/sshd_config con sudo, habilitando PasswordAuthentication yes y PermitRootLogin yes
2024-10-08 16:14:16	Reinicio del servicio SSH — la nueva configuración queda activa (ventana de ~86 minutos hasta el acceso)

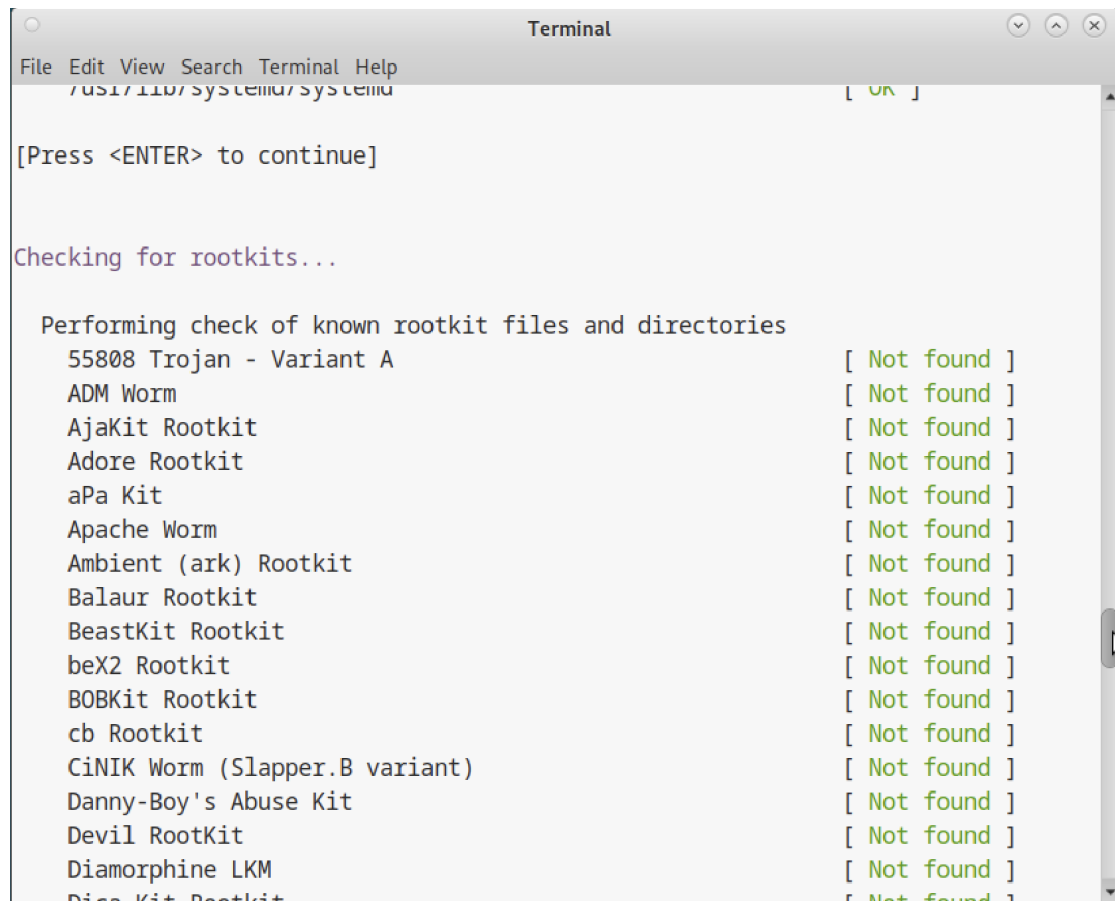
Timestamp	Evento
2024-10-08 17:40:59	Autenticación SSH exitosa como root desde 192.168.0.134 puerto 45623 (acceso no autorizado)
2024-10-08 17:40:59	Apertura de sesión privilegiada: pam_unix(sshd:session) session opened for user root(uid=0)

6. Escaneo de Seguridad del Sistema

Se ejecutaron herramientas de detección de rootkits para verificar la integridad del sistema y descartar la presencia de software malicioso instalado con posterioridad al acceso no autorizado.

Herramienta	Resultado	Observaciones
chkrootkit	Limpio	No se detectaron rootkits conocidos ni binarios del sistema comprometidos
rkhunter	Limpio	No se encontraron advertencias críticas. Integridad de binarios del sistema verificada

Los resultados de ambas herramientas indican que no se instalaron rootkits ni se comprometió la integridad de los binarios del sistema durante el período posterior al acceso no autorizado. Esto es consistente con la ausencia de actividad concluyente documentada en la sección 4.6.



```
Terminal
File Edit View Search Terminal Help
root@kali:~/usr/bin [ OK ]

[Press <ENTER> to continue]

Checking for rootkits...

Performing check of known rootkit files and directories
55808 Trojan - Variant A [ Not found ]
ADM Worm [ Not found ]
AjaKit Rootkit [ Not found ]
Adore Rootkit [ Not found ]
aPa Kit [ Not found ]
Apache Worm [ Not found ]
Ambient (ark) Rootkit [ Not found ]
Balaur Rootkit [ Not found ]
BeastKit Rootkit [ Not found ]
beX2 Rootkit [ Not found ]
BOBKit Rootkit [ Not found ]
cb Rootkit [ Not found ]
CiNIK Worm (Slapper.B variant) [ Not found ]
Danny-Boy's Abuse Kit [ Not found ]
Devil RootKit [ Not found ]
Diamorphine LKM [ Not found ]
Dica Kit Rootkit [ Not found ]
```

Resultados de chkrootkit y rkhunter

7. Análisis de Procesos del Sistema

Se realizó un análisis de los procesos activos en el sistema para identificar la presencia de procesos anómalos, backdoors o herramientas de ataque en ejecución:

```
ps aux --sort=start_time
```

La revisión no identificó procesos sospechosos, servicios no autorizados ni herramientas de ataque activas. Los procesos listados corresponden a los servicios legítimos del servidor (sshd, apache2, mysql, vsftpd) y procesos estándar del sistema operativo Debian.

USER	PID	%CPU	%MEM	VSZ	RSS	TTY	STAT	START	TIME	COMMAND
root	1	2.5	0.3	167876	12420	?	Ss	16:13	0:04	/sbin/init sp
root	2	0.0	0.0	0	0	?	S	16:13	0:00	[kthreadd]
root	3	0.0	0.0	0	0	?	I<	16:13	0:00	[rcu_gp]
root	4	0.0	0.0	0	0	?	I<	16:13	0:00	[rcu_par_gp]
root	5	0.0	0.0	0	0	?	I<	16:13	0:00	[slub_flushwq]
root	6	0.0	0.0	0	0	?	I<	16:13	0:00	[netns]
root	7	0.0	0.0	0	0	?	I	16:13	0:00	[kworker/0:0-
root	8	0.0	0.0	0	0	?	I<	16:13	0:00	[kworker/0:0H
root	9	0.0	0.0	0	0	?	I	16:13	0:00	[kworker/u8:0
root	10	0.0	0.0	0	0	?	I<	16:13	0:00	[mm_percpu_wq]
root	11	0.0	0.0	0	0	?	I	16:13	0:00	[rcu_tasks_kt
root	12	0.0	0.0	0	0	?	I	16:13	0:00	[rcu_tasks_ru
root	13	0.0	0.0	0	0	?	I	16:13	0:00	[rcu_tasks_tr
root	14	0.0	0.0	0	0	?	S	16:13	0:00	[ksoftirqd/0]
root	15	0.3	0.0	0	0	?	I	16:13	0:00	[rcu_preempt]
root	16	0.0	0.0	0	0	?	S	16:13	0:00	[migration/0]
root	17	0.1	0.0	0	0	?	I	16:13	0:00	[kworker/0:1-
root	18	0.0	0.0	0	0	?	S	16:13	0:00	[cpuhp/0]
root	19	0.0	0.0	0	0	?	S	16:13	0:00	[cpuhp/1]
root	20	0.0	0.0	0	0	?	S	16:13	0:00	[migration/1]
root	21	0.0	0.0	0	0	?	S	16:13	0:00	[ksoftirqd/1]
root	22	0.0	0.0	0	0	?	I	16:13	0:00	[kworker/1:0-

Procesos activos del sistema

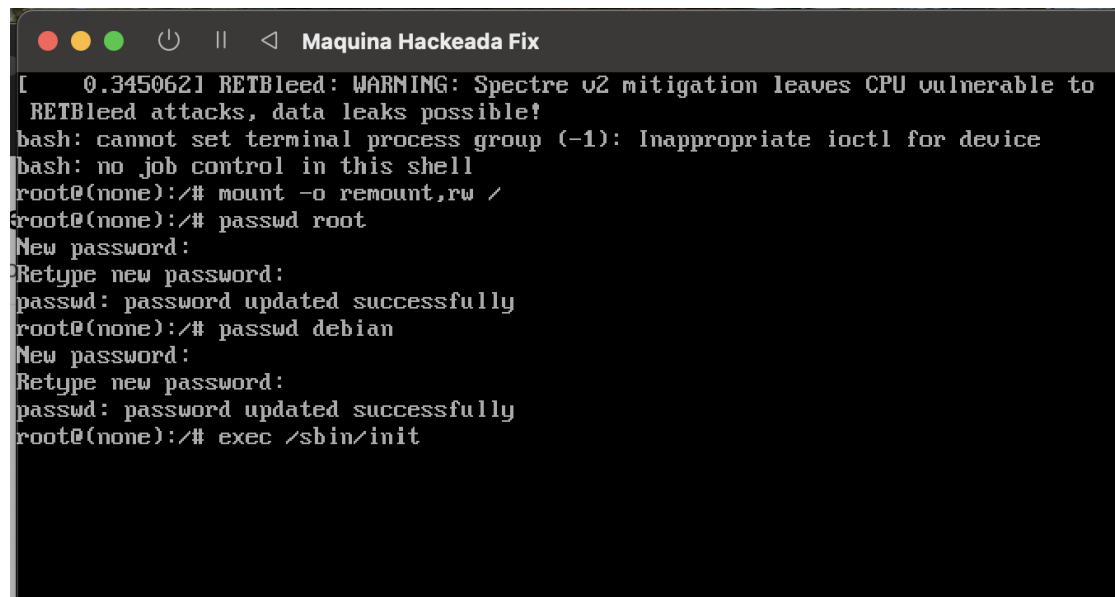
8. Acciones Correctivas Implementadas

Una vez confirmado el incidente, se implementaron las siguientes acciones correctivas sobre el servidor comprometido:

Cambio de contraseñas

Se actualizaron las contraseñas de las cuentas privilegiadas del sistema, aplicando una política de contraseñas robustas (mínimo 12 caracteres, combinación de mayúsculas, minúsculas, números y símbolos):

```
passwd root
passwd debian
```



```
[ 0.345062] RETbleed: WARNING: Spectre v2 mitigation leaves CPU vulnerable to
RETbleed attacks, data leaks possible!
bash: cannot set terminal process group (-1): Inappropriate ioctl for device
bash: no job control in this shell
root@(none):/# mount -o remount,rw /
root@(none):/# passwd root
New password:
Retype new password:
passwd: password updated successfully
root@(none):/# passwd debian
New password:
Retype new password:
passwd: password updated successfully
root@(none):/# exec /sbin/init
```

Cambio de contraseñas de cuentas privilegiadas

Endurecimiento de configuración SSH

Se corrigieron las directivas inseguras en /etc/ssh/sshd_config que posibilitaron el acceso no autorizado:

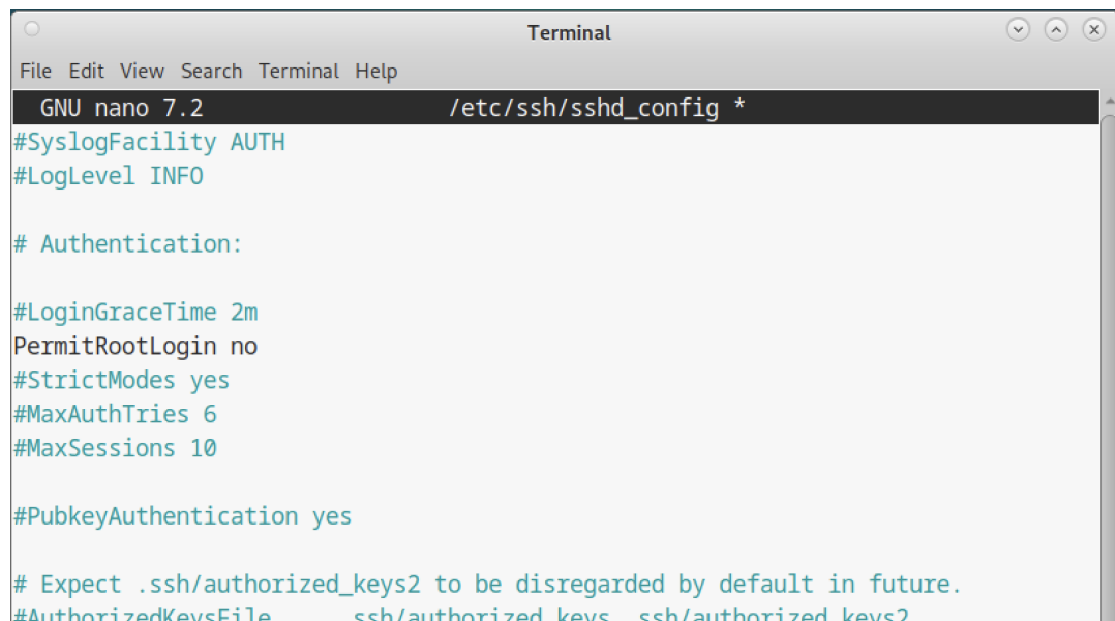
PermitRootLogin no

PasswordAuthentication no

AllowUsers debian

Tras aplicar los cambios, el servicio SSH fue reiniciado para activar la nueva configuración:

systemctl restart ssh



```
GNU nano 7.2 /etc/ssh/sshd_config *
#SyslogFacility AUTH
#LogLevel INFO

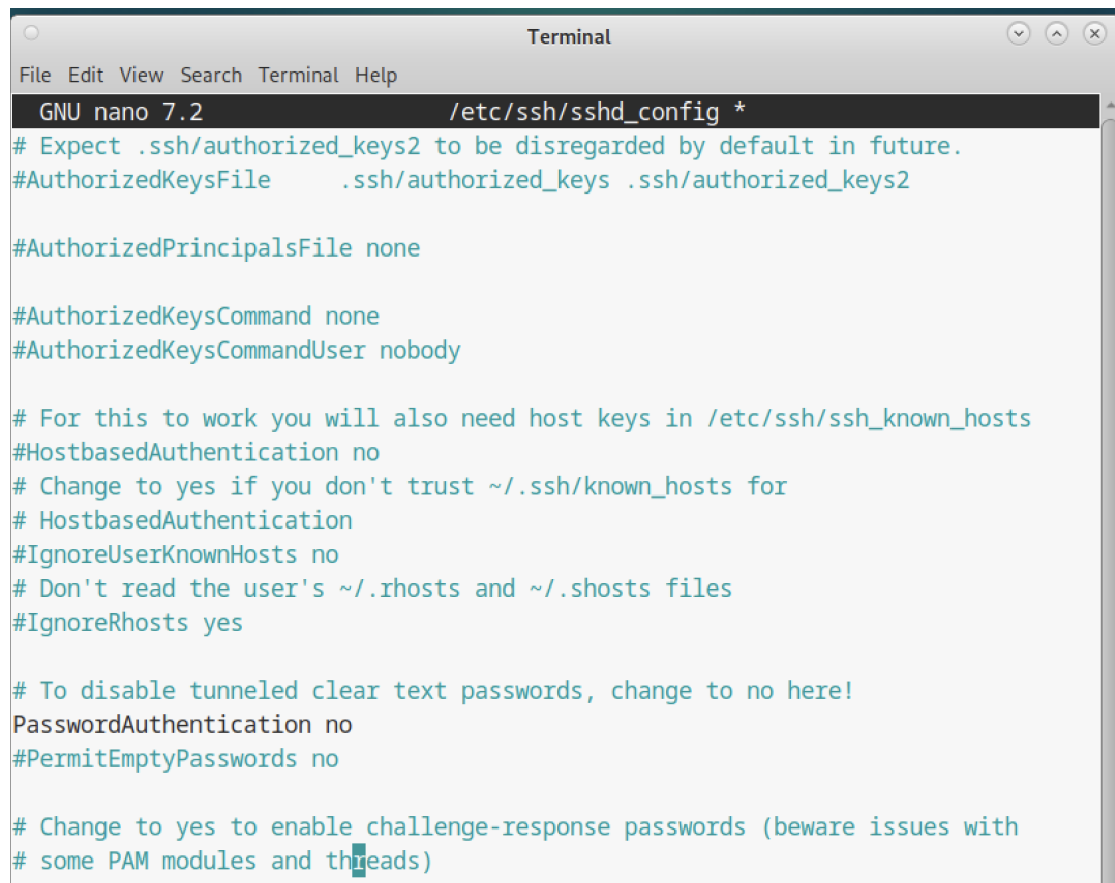
# Authentication:

#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile .ssh/authorized keys .ssh/authorized keys2
```

Configuración SSH endurecida



```
Terminal
File Edit View Search Terminal Help
GNU nano 7.2 /etc/ssh/sshd_config *
# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
PasswordAuthentication no
#PermitEmptyPasswords no

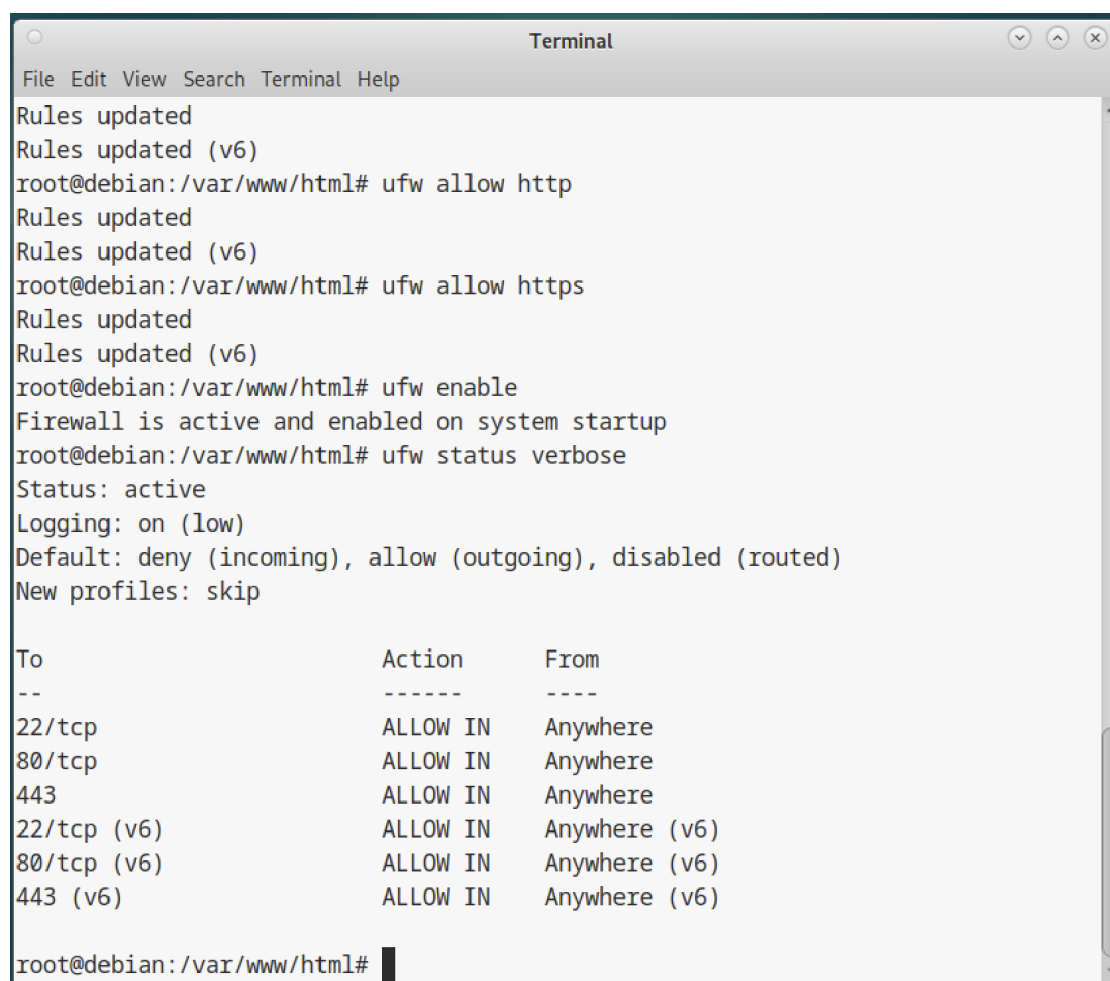
# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
```

Generación de claves públicas para autenticación segura

Implementación de firewall

Se configuraron reglas de firewall para restringir el acceso al servicio SSH únicamente a direcciones IP autorizadas, reduciendo la superficie de ataque expuesta:

```
ufw enable
ufw default deny incoming
ufw allow from [IP_AUTORIZADA] to any port 22
```



```
Terminal
File Edit View Search Terminal Help
Rules updated
Rules updated (v6)
root@debian:/var/www/html# ufw allow http
Rules updated
Rules updated (v6)
root@debian:/var/www/html# ufw allow https
Rules updated
Rules updated (v6)
root@debian:/var/www/html# ufw enable
Firewall is active and enabled on system startup
root@debian:/var/www/html# ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22/tcp ALLOW IN Anywhere
80/tcp ALLOW IN Anywhere
443 ALLOW IN Anywhere
22/tcp (v6) ALLOW IN Anywhere (v6)
80/tcp (v6) ALLOW IN Anywhere (v6)
443 (v6) ALLOW IN Anywhere (v6)

root@debian:/var/www/html#
```

Configuración de reglas UFW

Revisión de permisos del sistema

Se auditaron los permisos de archivos y directorios críticos del sistema, así como las entradas en `/etc/sudoers`, para identificar y corregir configuraciones permisivas que pudieran facilitar una escalada de privilegios:

```
cat /etc/sudoers
find / -perm -4000 -type f 2>/dev/null
```

9. Validación de Remediaciones

Se realizaron las siguientes pruebas para confirmar que las acciones correctivas fueron aplicadas correctamente y que las vulnerabilidades identificadas fueron mitigadas:

Prueba	Comando utilizado	Resultado esperado
Verificar PermitRootLogin deshabilitado	<code>sshd -T grep permitrootlogin</code>	permitrootlogin no
Verificar autenticación por contraseña deshabilitada	<code>sshd -T grep passwordauthentication</code>	passwordauthentication no

Prueba	Comando utilizado	Resultado esperado
Confirmar acceso SSH como root rechazado	ssh root@192.168.64.9	Permission denied (publickey)
Validar reglas firewall activas	ufw status verbose	Firewall activo, puerto 22 restringido

Se validó que los servicios expuestos y configuraciones vulnerables fueron mitigados. Las pruebas de conexión SSH confirmaron que el acceso como root mediante contraseña es rechazado bajo la nueva configuración.

```
root@debian:~# sshd -T | grep permitrootlogin
permitrootlogin yes
root@debian:~# sshd -T | grep passwordauthentication
passwordauthentication yes
```

Verificación de configuración SSH corregida

```
operador@debian-analista:~$ ssh root@192.168.64.9
root@192.168.64.9: Permission denied (publickey).
```

Acceso SSH como root rechazado

```
root@debian:/var/www/html# ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22/tcp ALLOW IN Anywhere
80/tcp ALLOW IN Anywhere
443 ALLOW IN Anywhere
22/tcp (v6) ALLOW IN Anywhere (v6)
80/tcp (v6) ALLOW IN Anywhere (v6)
443 (v6) ALLOW IN Anywhere (v6)
```

Estado del firewall UFW activo

10. Recomendaciones

- Deshabilitar autenticación SSH por contraseña — ya implementado como acción correctiva. Mantener esta configuración de forma permanente y verificarla en cada ciclo de auditoría.
- Utilizar autenticación mediante claves públicas — generar par de claves RSA de mínimo 4096 bits o claves Ed25519 para todos los usuarios con acceso remoto.
- Restringir acceso root por SSH — ya implementado. Adicionalmente, considerar el uso de sudo con registro de auditoría para comandos privilegiados.
- Monitorear logs regularmente — implementar un sistema centralizado de gestión de logs (SIEM) y configurar alertas automáticas ante eventos de autenticación fallida y exitosa en SSH.

-
- Implementar autenticación de doble factor (MFA) para el acceso SSH, especialmente para cuentas con privilegios elevados.
 - Establecer un proceso de gestión de cambios — la modificación de `sshd_config` sin un proceso de autorización y revisión fue el vector que habilitó el incidente. Todo cambio en configuraciones de seguridad debe ser documentado, autorizado y auditado.
 - Realizar análisis de vulnerabilidades periódicos con herramientas como OpenVAS o Nessus para identificar configuraciones inseguras de forma proactiva.

11. Conclusión

La investigación forense confirmó un acceso no autorizado al servidor Debian mediante SSH como root desde la IP 192.168.0.134. Aunque no se identificaron evidencias concluyentes de actividad maliciosa posterior ni de persistencia en el sistema, el acceso no autorizado constituye un incidente crítico de seguridad.

La causa raíz del incidente fue la habilitación deliberada de las directivas `PasswordAuthentication` y `PermitRootLogin` en el archivo de configuración SSH, efectuada por el usuario `debian` con privilegios de `sudo` a las 16:12:55, seguida del reinicio del servicio a las 16:14:16. Estas acciones eliminaron las barreras de seguridad por defecto del sistema y dejaron el acceso root expuesto a autenticación por contraseña desde cualquier dirección de red durante aproximadamente 86 minutos antes del acceso no autorizado.

Las medidas correctivas implementadas mitigan el vector de ataque utilizado. Se recomienda mantener las configuraciones aplicadas; implementar las recomendaciones adicionales descritas en la sección 10, y establecer un proceso formal de gestión de cambios en configuraciones de seguridad para prevenir incidentes similares.

Jose Muñoz A

Analista de Seguridad - NexusTrace S.A.S

Marzo 2026